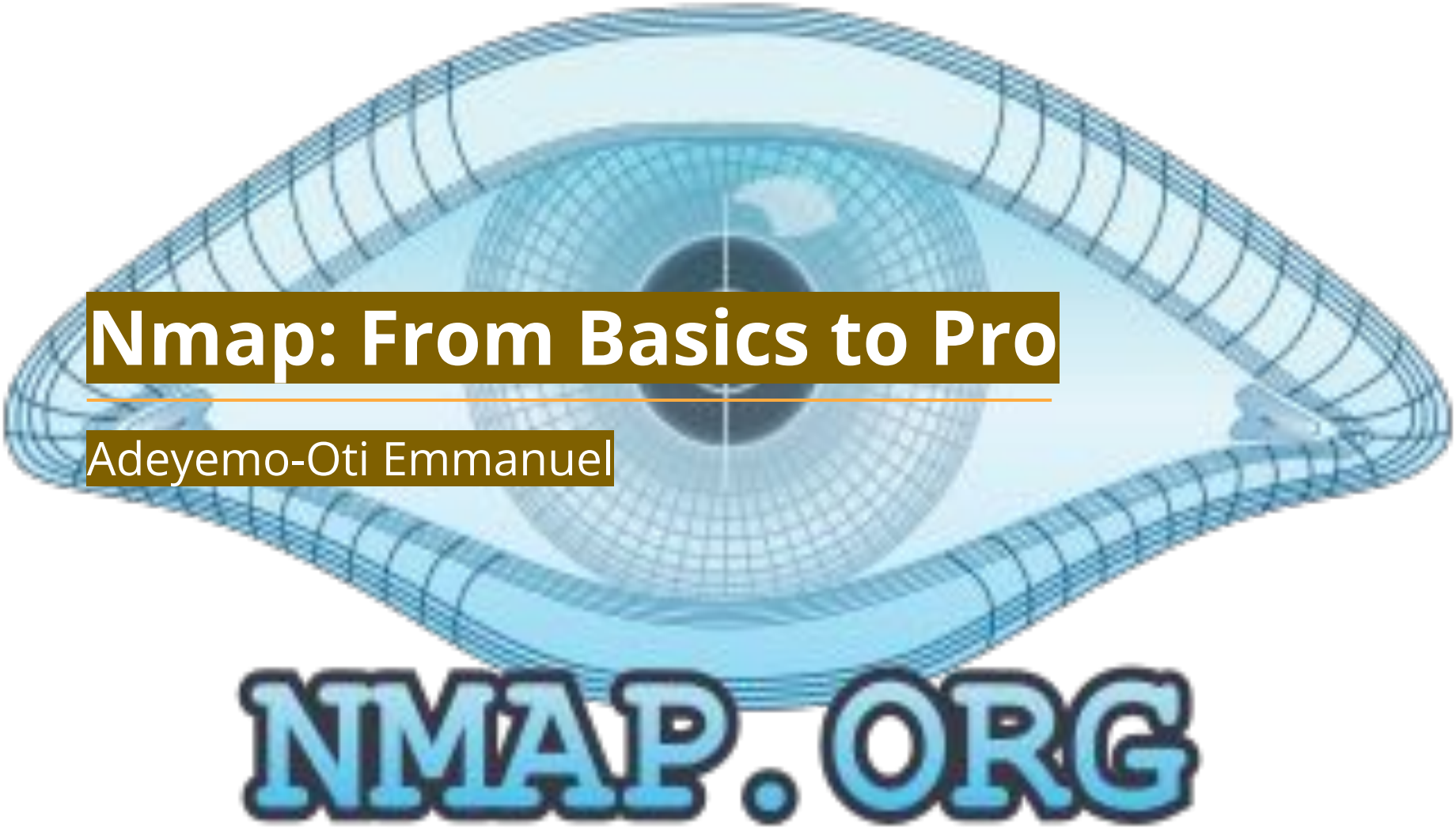
Nmap: From Basics to Pro

Adeyemo-Oti Emmanuel



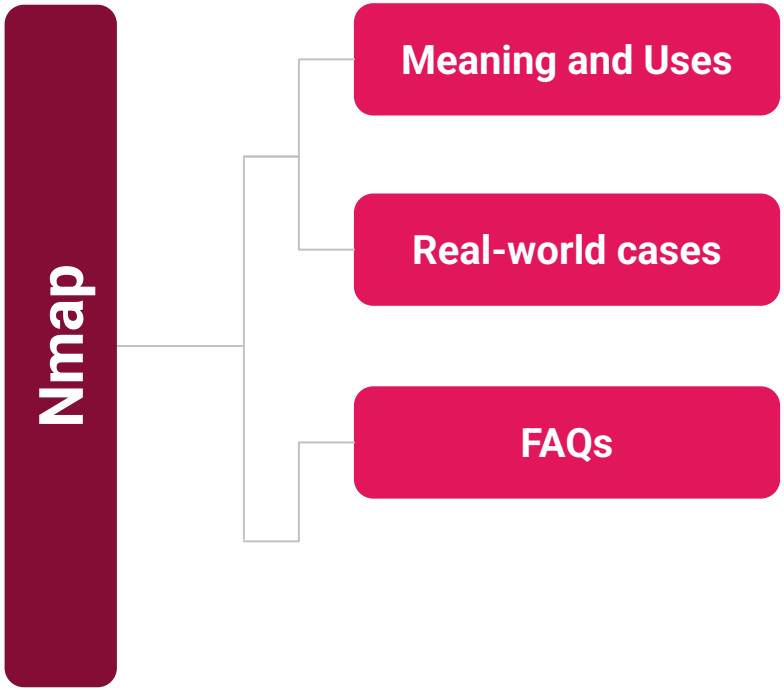
Overview

I put together the basics I believe would be useful for beginners when it comes to using Nmap. It runs from beginner to intermediate level.

Enjoy!

Learn more about Nmap here.

What’s Covered in this Document



Tools

- VirtualBox
- Kali Linux
- Metasploitable 3 or OWASP Top 10

Nmap

Nmap is an open-source tool used for network discovery and security auditing by scanning hosts and services on a computer network.

It helps identify open ports, running services, and operating system details, making it valuable for both network administrators and ethical hackers.

Nmap commonly performs TCP connect scans, SYN (stealth) scans, UDP scans, ACK scans, FIN scans, Xmas scans, Null scans, and OS detection scans.

Nmap Scans

- TCP Connect Scan – nmap -sT <target>
- SYN Scan (Stealth Scan) – nmap -sS <target>
- UDP Scan – nmap -sU <target>
- ACK Scan – nmap -sA <target>
- FIN Scan – nmap -sF <target>
- Xmas Scan – nmap -sX <target>
- Null Scan – nmap -sN <target>
- OS Detection Scan – nmap -O <target>
- Ping Scan (Host Discovery) – nmap -sn <target>
- Version Detection – nmap -sV <target>
- Aggressive Scan – nmap -A <target>

Nmap Timing

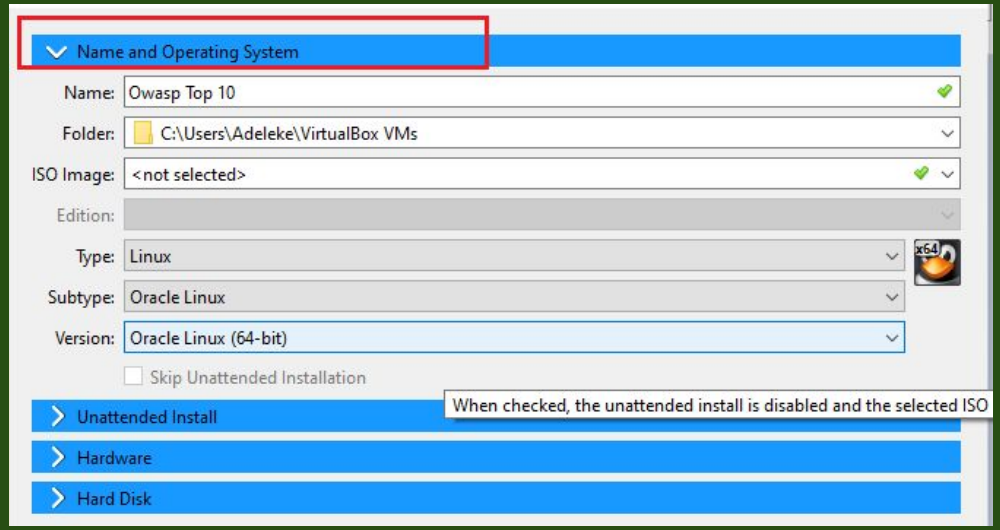
- T0 – Paranoid (very slow, useful for evading Intrusion Detection Systems)
- T1 – Sneaky (slow, still aimed at avoiding detection)
- T2 – Polite (slows down scan to reduce network load)
- T3 – Normal (default timing)
- T4 – Aggressive (faster, suitable for stable networks and trusted environments)
- T5 – Insane (very fast, may overwhelm networks or miss results)

Use these with your scan like this: nmap -T4 -sS <target>

Installation of Target

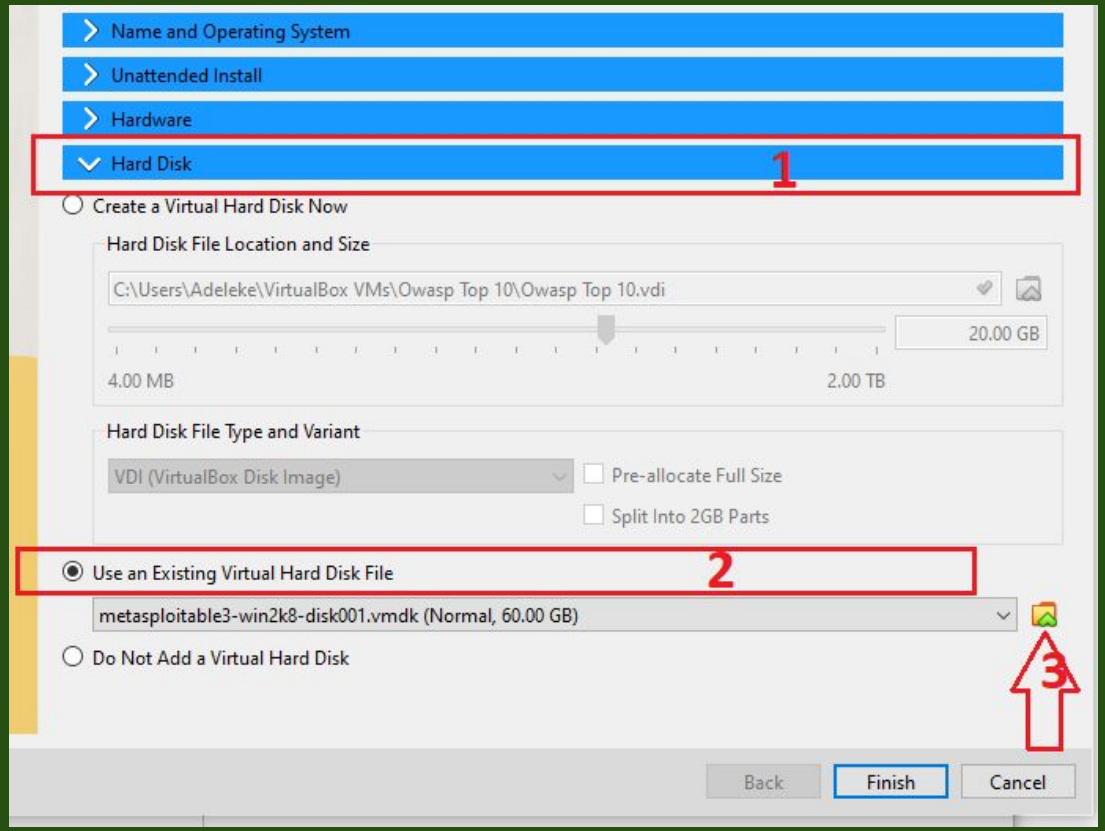
Use this link to download the OWASP Top 10 Zip File.

- Locate the download folder, and unzip the file.
- Open your Oracle Virtual Box and click New and fill the name, type, subtype, and version as shown below:



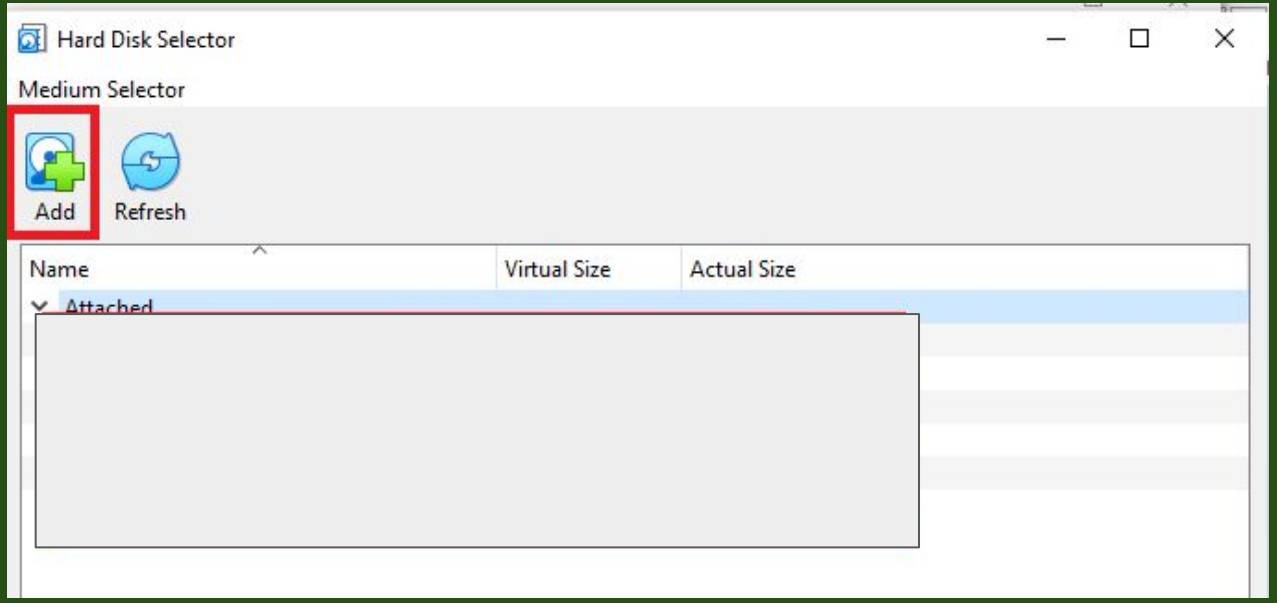
Installation of Target

- Select Hard Disk and follow the step below:



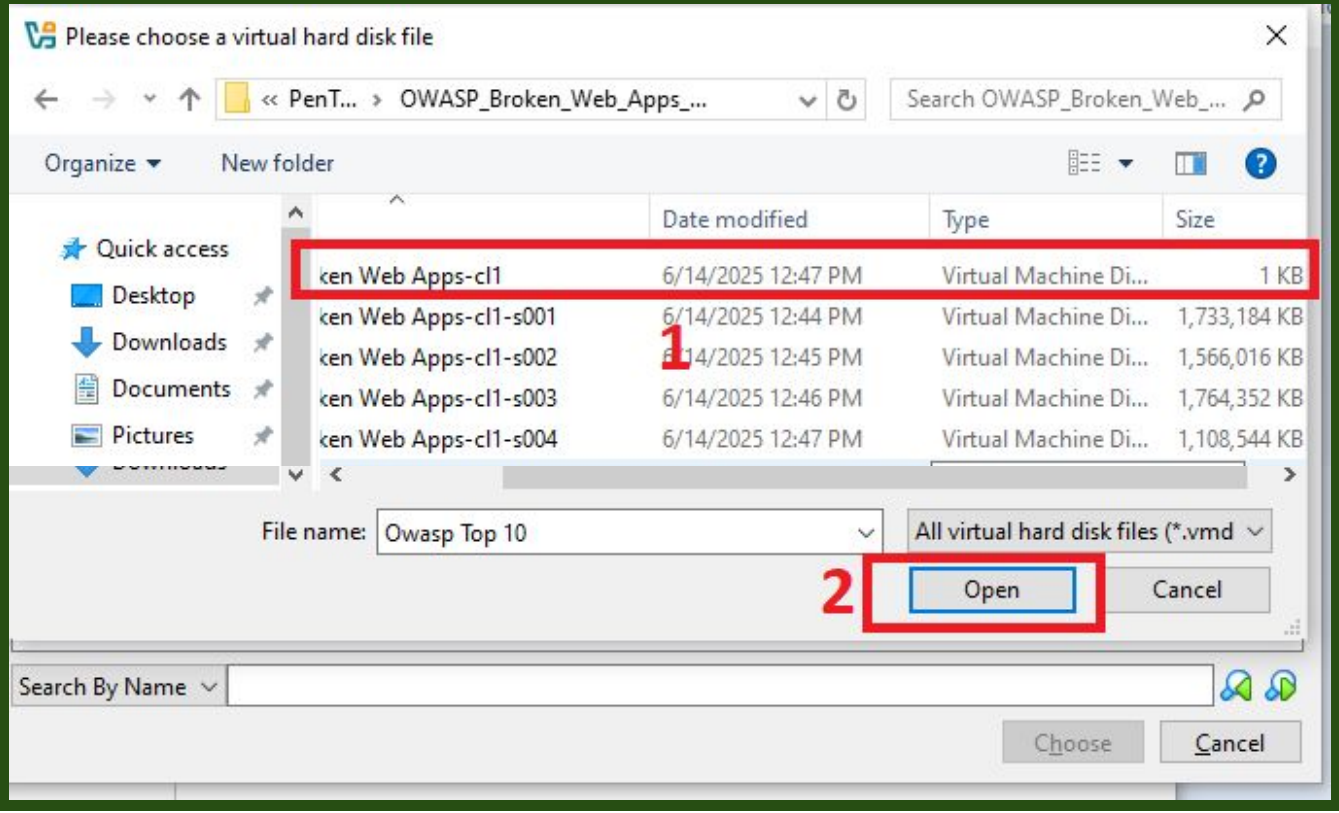
Installation of Target

- Select the Add icon



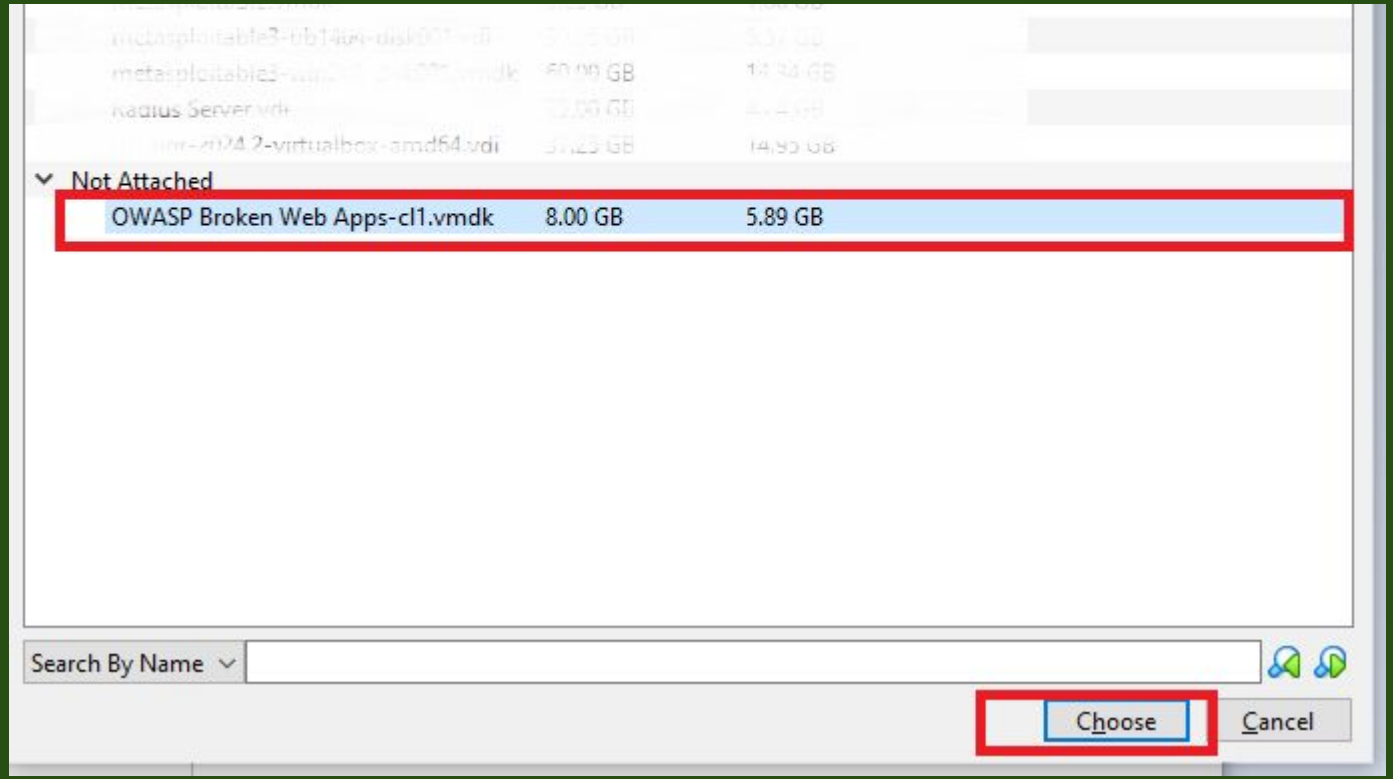
Installation of Target

- Open the folder where you extract the OWASP ISO file and choose the first one with the 1kb size



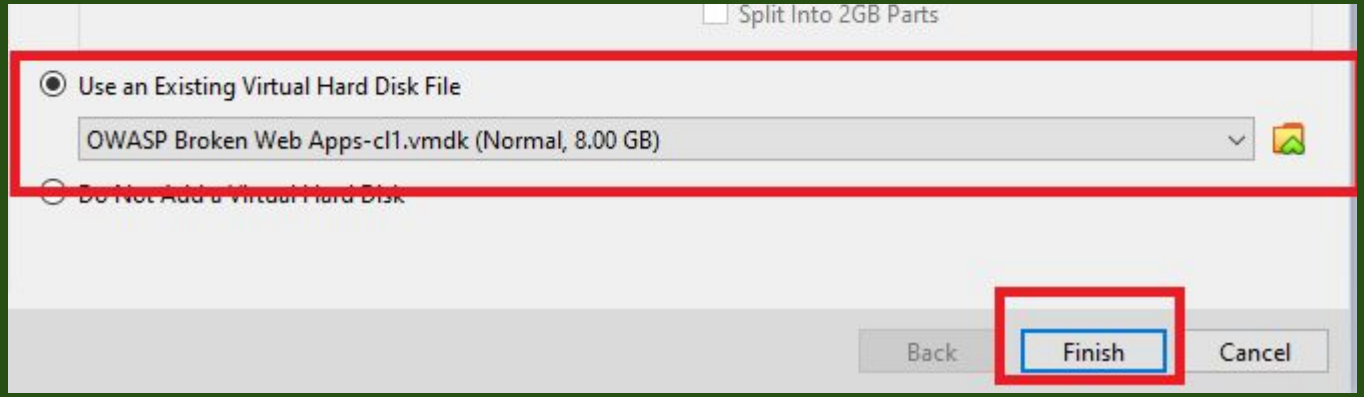
Installation of Target

- Click Choose to continue



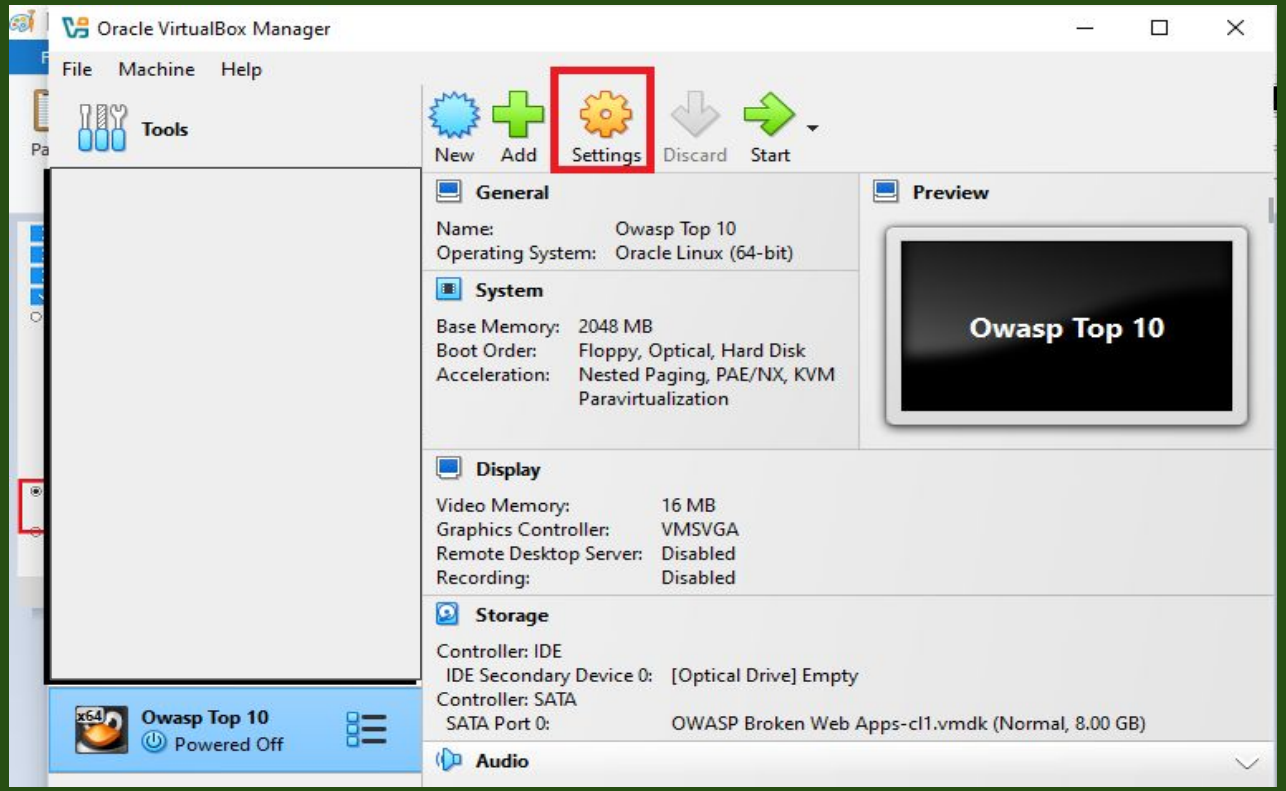
Installation of Target

- You have this screen. Click Finish



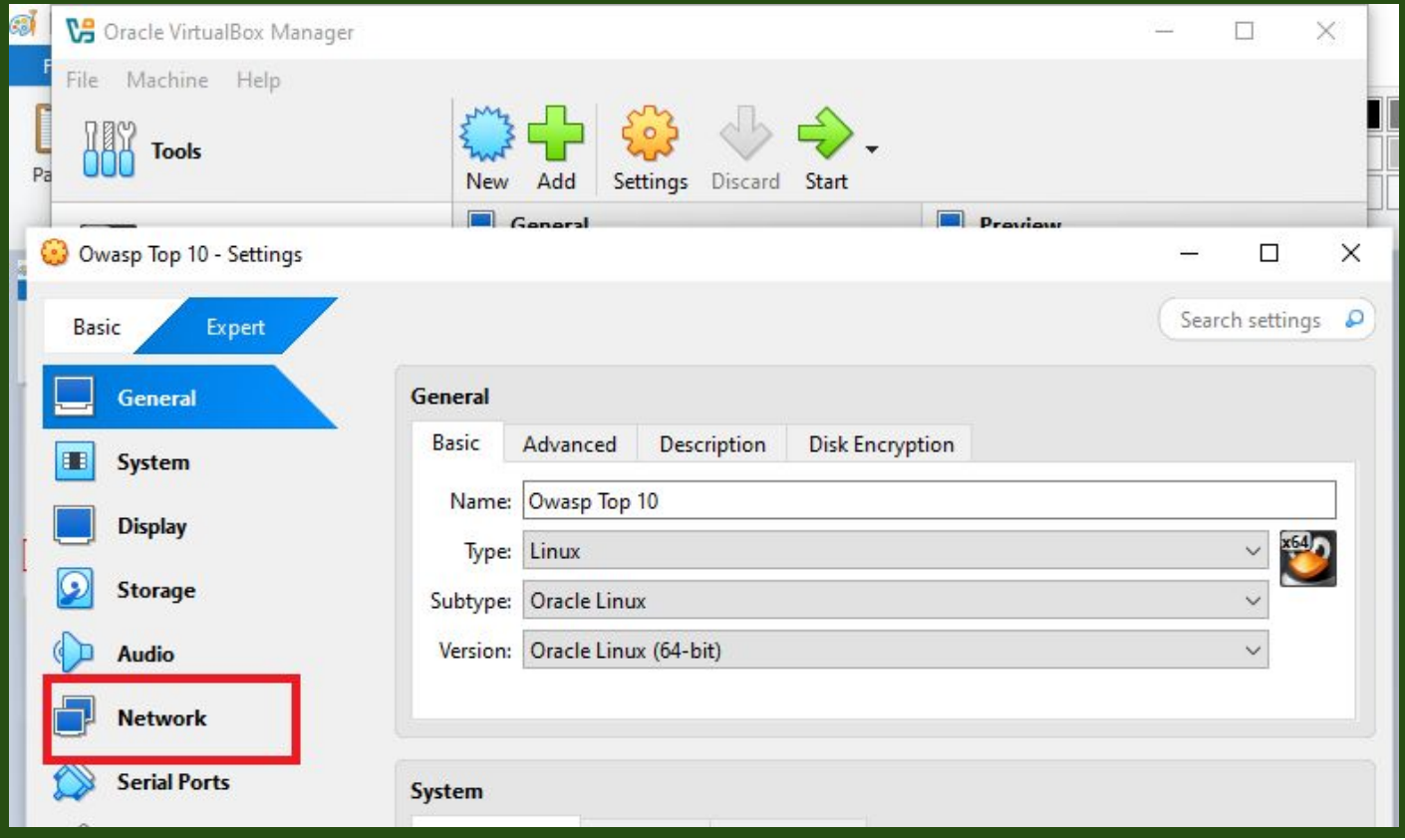
Installation of Target

- With the Owasp Top 10 selected, click on the Settings icon



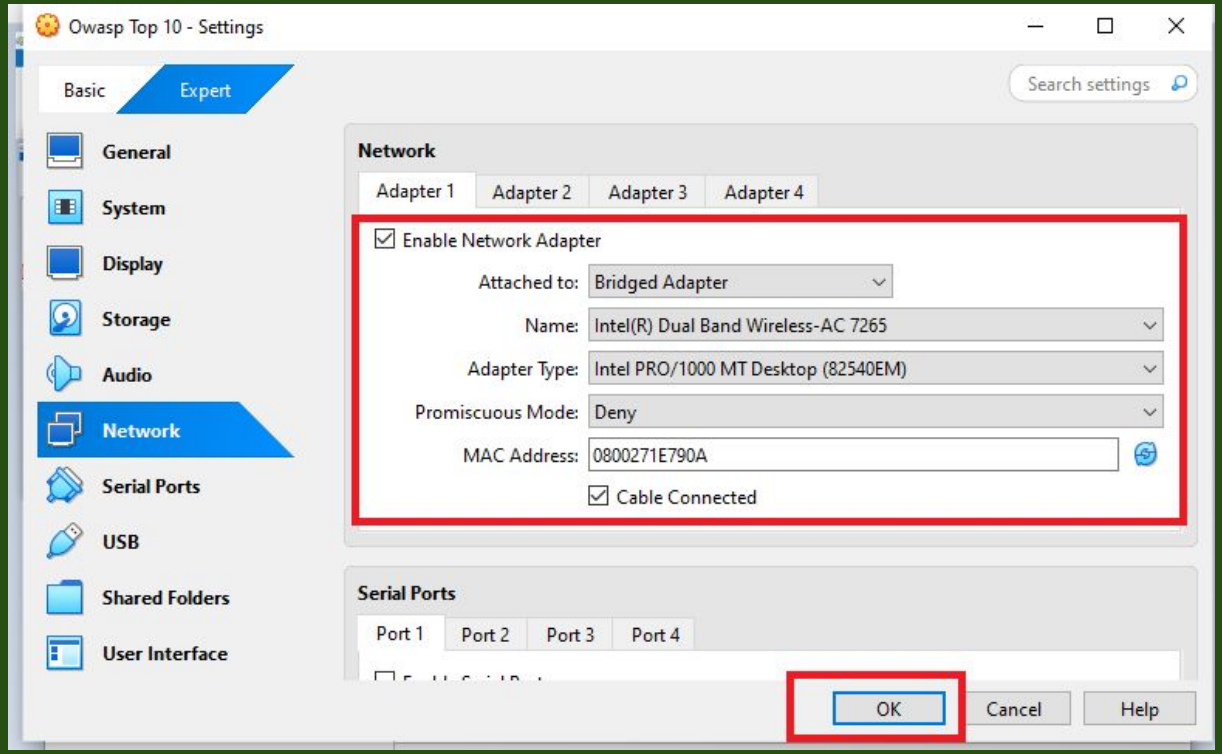
Installation of Target

- On the Settings page, select Network



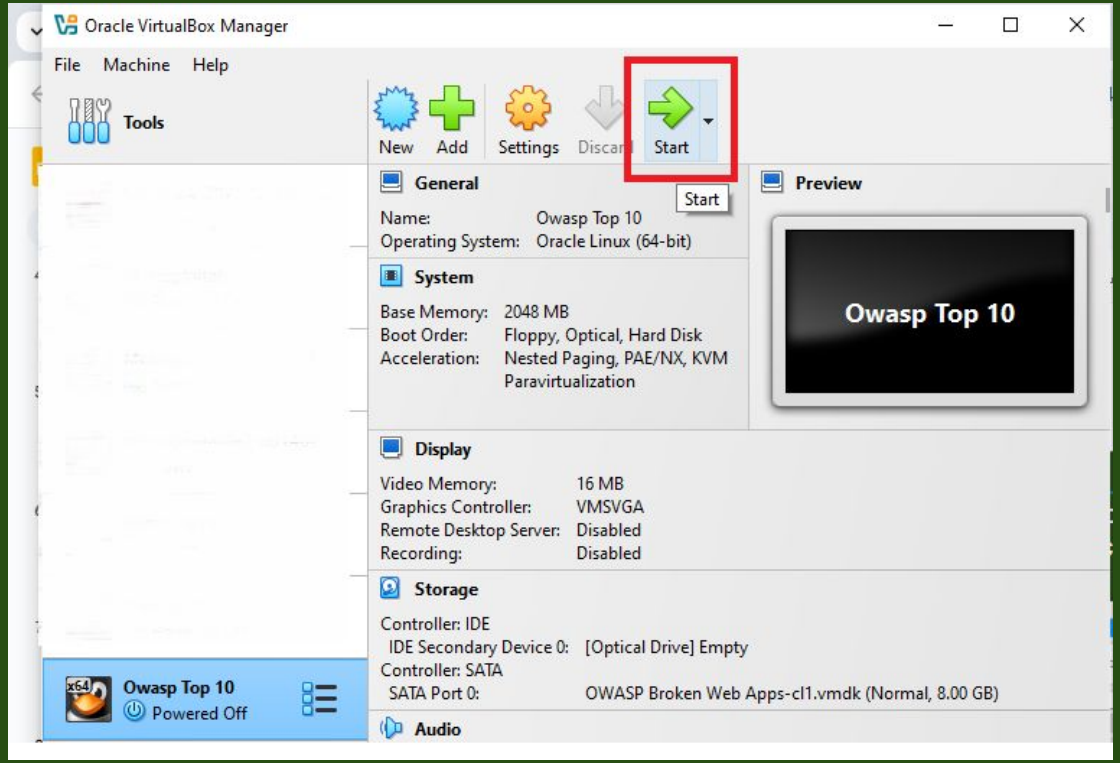
Installation of Target

- Use the Expert mode and adjust your settings as shown below. The Name varies depending on your ISP. Click OK.



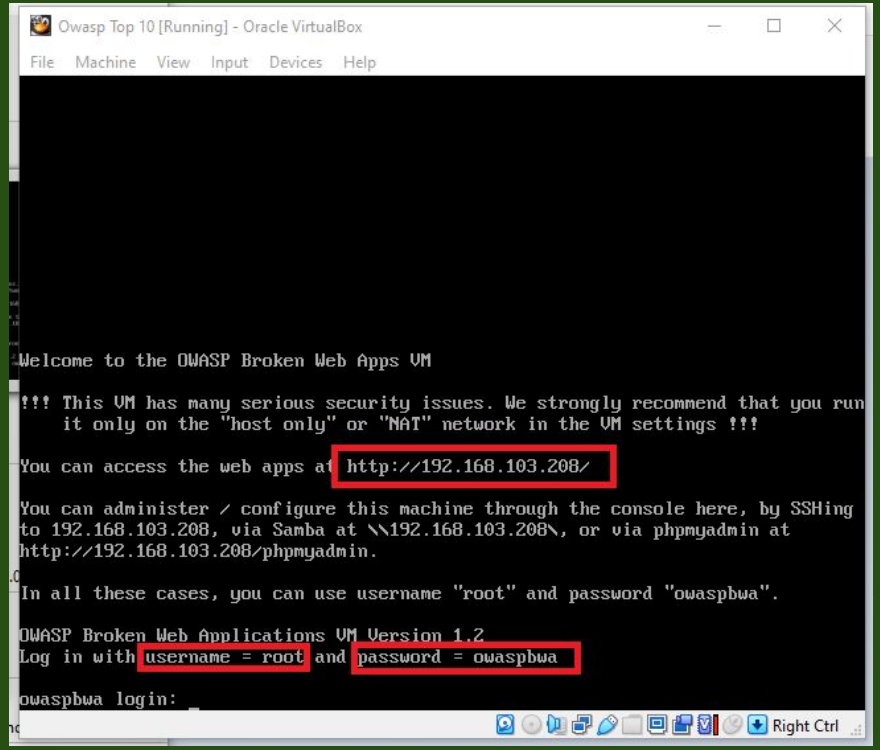
Installation of Target

- With the OWASP selected, click start



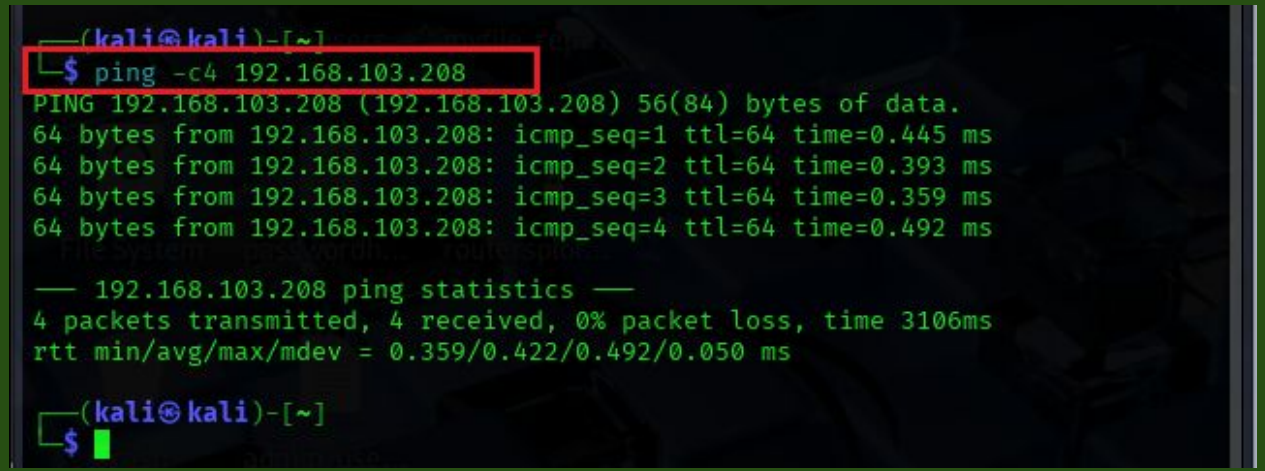
Installation of Target

- As you can see, you have the IP address to interact with this machine. It's not going to be the same as yours. Log in with the username and password



Installation of Target

Check if everything is fine by pinging the OWASP IP address from Kali. I sent an ICMP packet 4 times as shown below:



So right now, everything is fine. You can open Mozilla in Kali and enter the OWASP IP address. It will lead you to the OWASP collections but that's not what we're doing right now.

Using Nmap Scans

Before you do anything, make sure to change your MAC address for some measure of anonymity. Do the following:

- Enter "ifconfig" to know your current IP address on the etho interface
- Enter "*sudo ifconfig etho down*" to turn off the eth0 interface
- Enter "*sudo macchanger -A eth0*". The "-A" flag helps to set random MAC of any type.
- Enter "*sudo ifconfig eth0 up*" to activate the eth0 interface.
- Enter "ifconfig" again. The MAC address would have changed now.

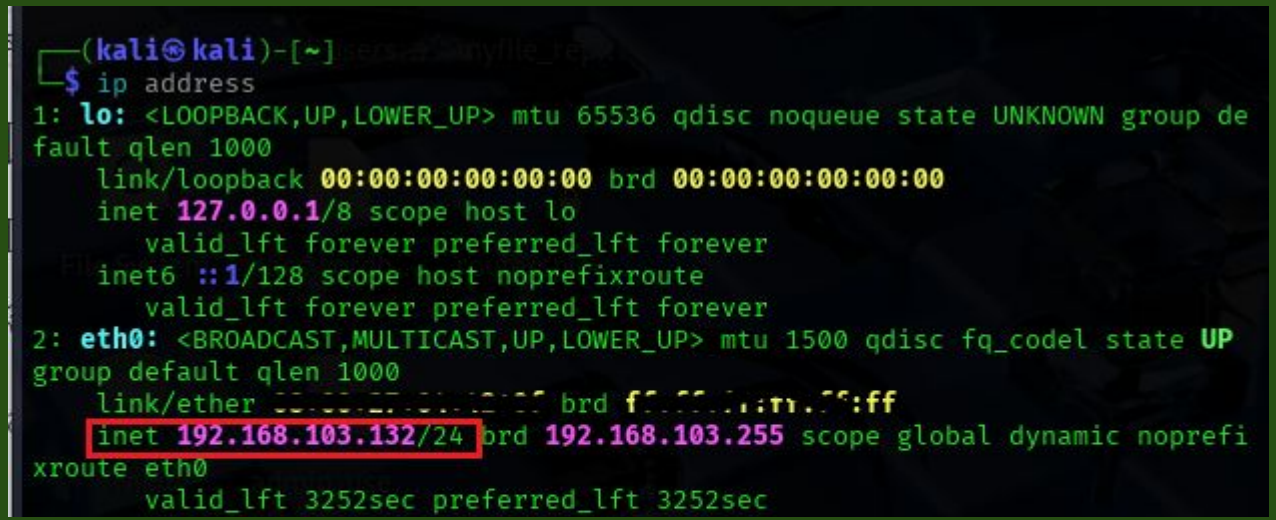
Remember that once you restart your Kali, the spoofed MAC is gone.

To verify the spoofed MAC address, visit https://macvendors.com/ and enter the MAC address.

Let's start using Nmap for active recon.

Using Nmap Scans

Enter IP address to know

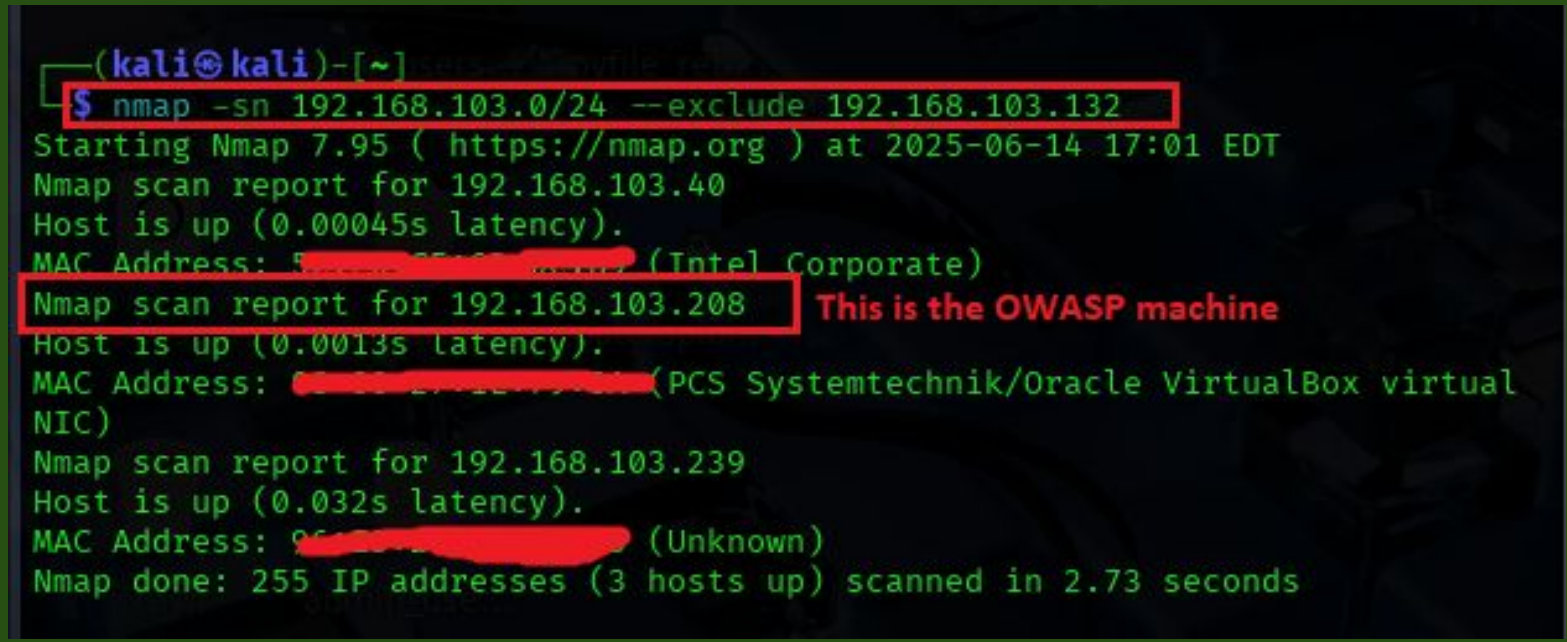


You can see that my Kali Linux and the OWASP are on the same local network 192.168.103.0/24 with the OWASP IP being 192.168.103.208

Using Nmap for Host Discovery

Let's discover hosts available on our network.

- Enter "*nmap -sn 192.168.103.0/24 –exclude 192.168.103.132*". The "--exclude" flag is used to not include the attacker's IP address in the result.



Using Nmap for open ports, services, and OS

Let's discover open ports, the services the ports are running, and their OS.

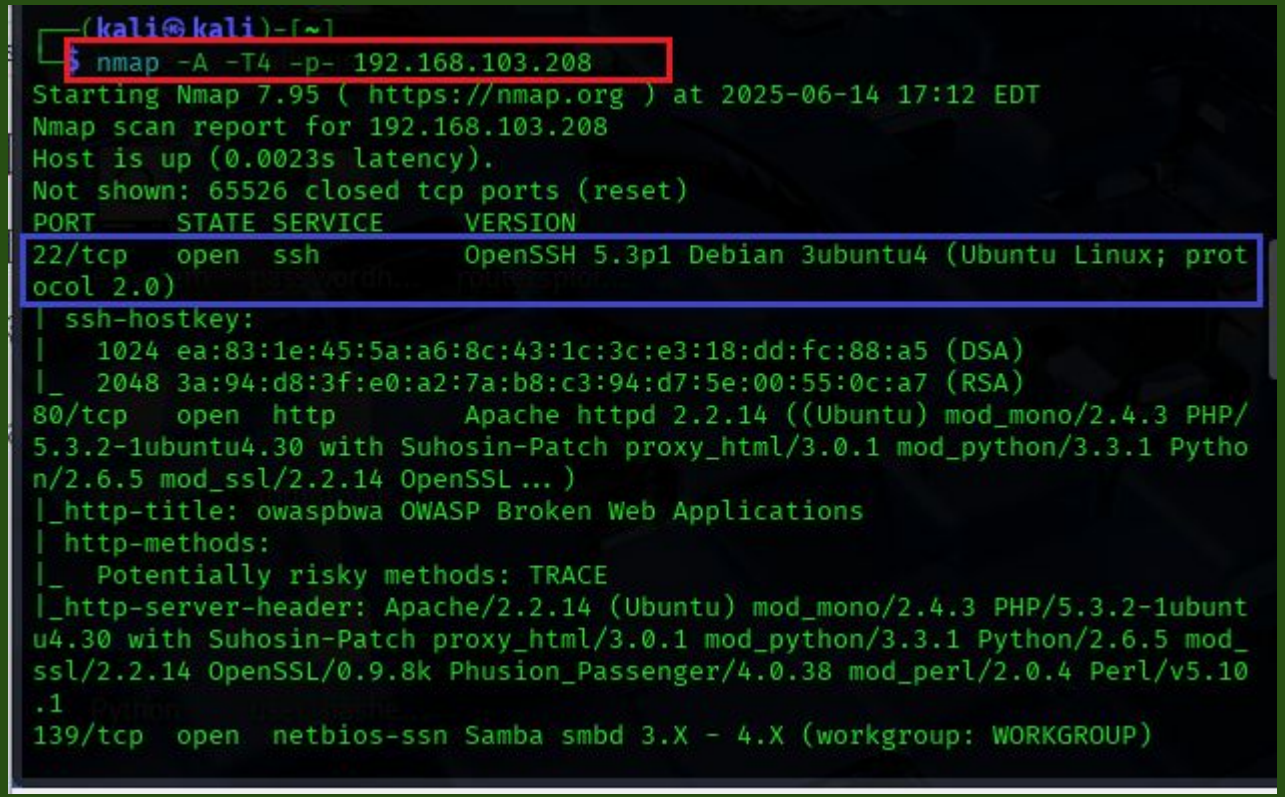
- Enter "*nmap 192.168.103.208*". Use the IP address for your OWASP. I used the one for my OWASP here. What did you notice? You should see the ports, state, and their services
- You can take it a little bit deeper to know the version of service your target is running as well as the SMB details by entering: "nmap -A -T4 -p- *192.168.103.208"*.

Here's the breakdown of the comand:

- -A: profile target and identifies OS, service version, traceroute, etc.
- -T is the timing
- -p- is to scan for all 65,535 ports

Check the output below:

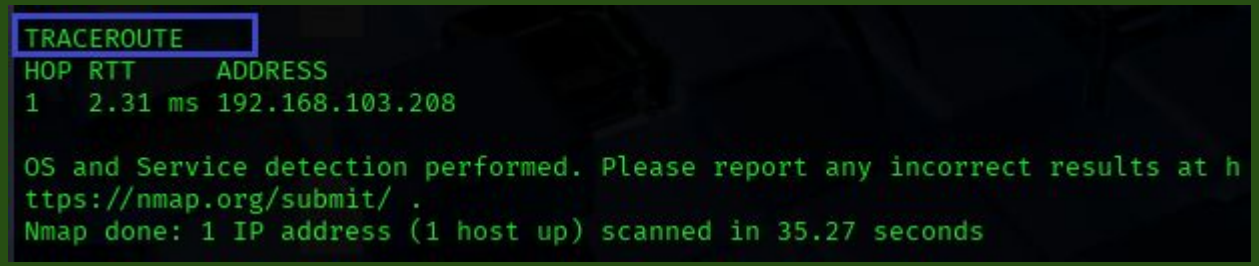
Using Nmap for open ports, services, and OS



Using Nmap for open ports, services, and OS



Using Nmap for open ports, services, and OS



As you can see from the screenshots above, we were able to see vital information about the target. You can see if the target is running outdated version of a service. If that is so, you discovered vulnerabilities already you can exploit.

Using Nmap

Nmap also has other uses:

- -Pn: Scans without discovering hosts and just tells you which host is online
- -sU: Performs UDP scan to identify if any services are running on the UDP ports compared to TCP ports
- -p: Used to indicate port number or range.
- -sV: Determines service version on the target

Using Nmap: Avoiding Detection

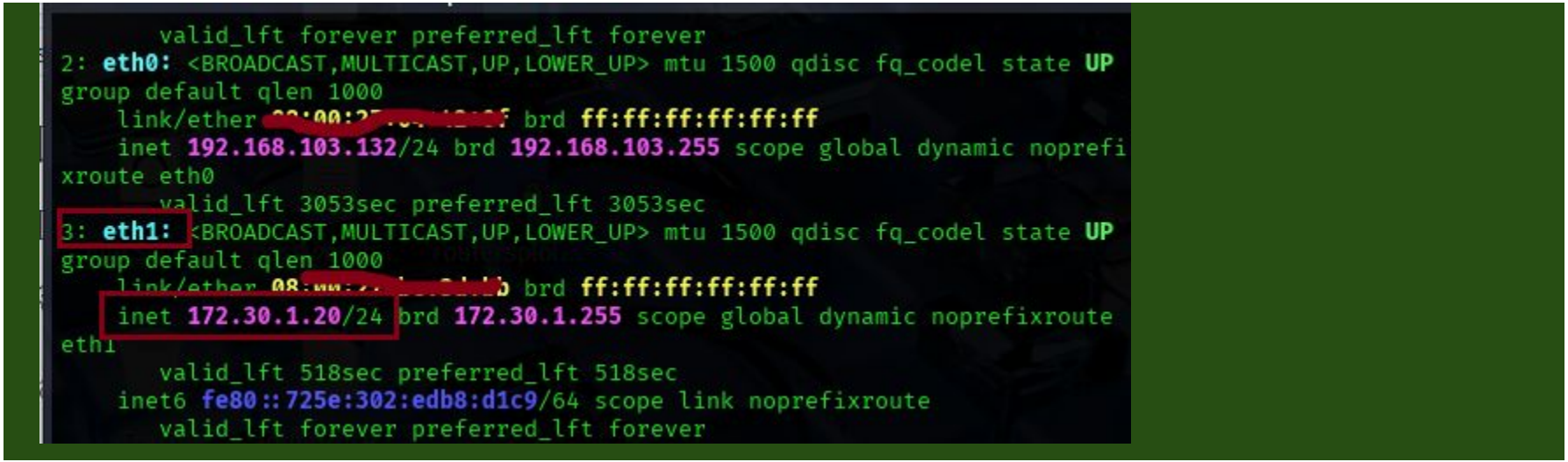
Nmap interacts with the target actively and that means it can be discovered. To evade detection, you can use decoy. Decoy makes the target system to think the scan source is originating from multiple sources instead of the pen tester's.

Let's say you want to attack the IP address 172.30.1.21 (A) and your IP address is 172.30.1.20 (B), you will use a decoy with IP address 172.30.1.22 (C).

A = Metasploitable 2
B = Attacker's IP
C = Metasploitable 3

The three devices are on the same network 172.30.1.0/24.

Using Nmap: Avoiding Detection



My Kali is interacting with the 172.30.1.0/24 network on the eth1 interface.
To evade the detection, I use the C as decoy, B as the attacking device and A as the target by entering: "*sudo nmap 172.30.1.21 -D 172.30.1.22*".
The scan won't originate from the 172.30.1.20 (B) IP address only but also includes C, if you check on Wireshark on the target's end

Using Nmap: Spoofing MAC and IP

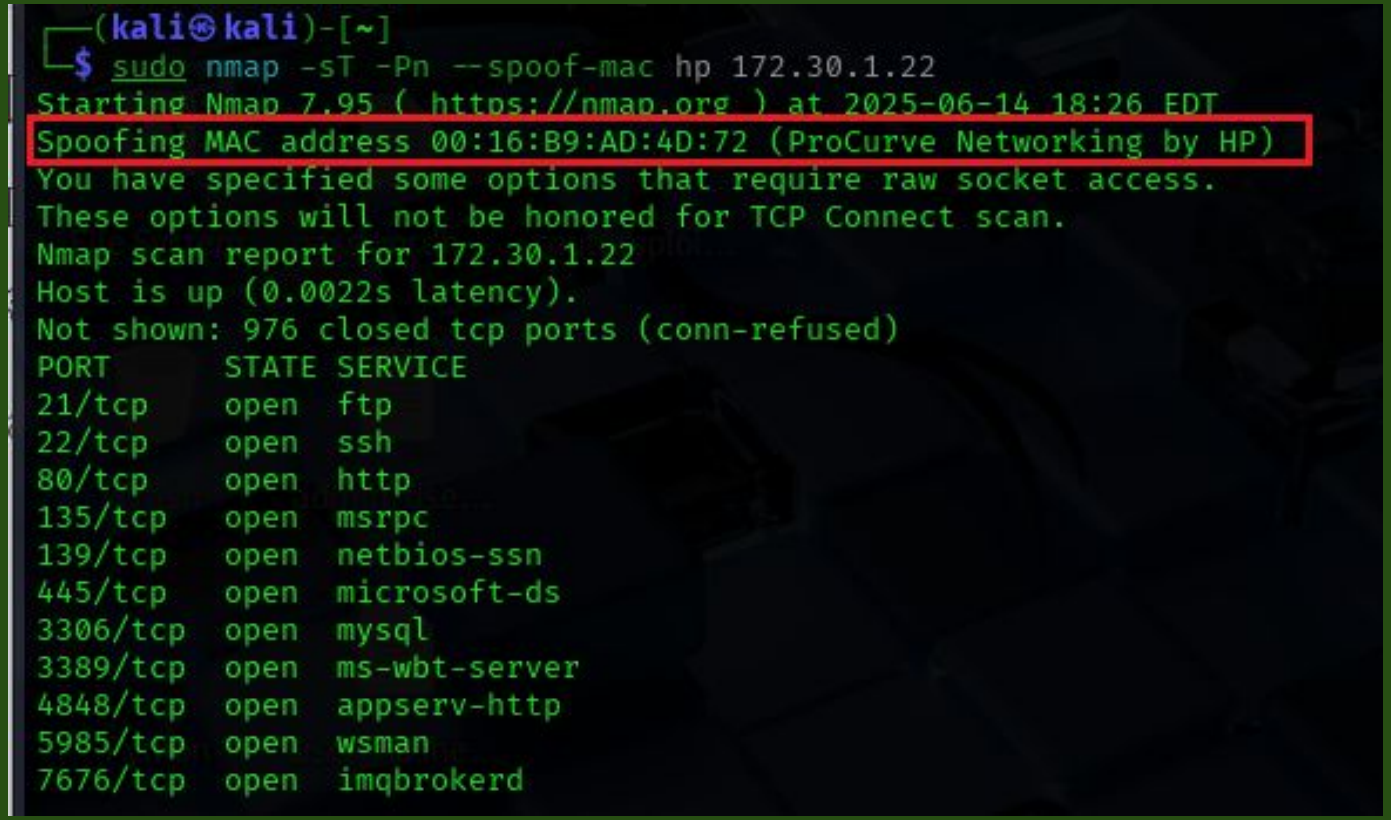
You can also spoof your MAC address to scan your target.
To do so, enter "*sudo nmap --spoof-mac 0 172.30.1.22".* Remember to replace the IP address with your OWASP IP address.

So the cool part is that if you run the same command 10 times, it's going to generate different spoofed MAC addresses for each attempt.

Make it deeper by entering: "*sudo nmap -sT -Pn --spoof-mac hp 172.30.1.22*" to spoof an HP device MAC address. Use your OWASP IP address.

Check the next slide for screenshot

Using Nmap: Spoofing MAC and IP



Using Nmap: Different Scanning Techniques

Nmap forms a TCP three-way handshake on any open TCP ports it discovers. You can read up on that. Try the following scans:

- *sudo nmap -sS -p 80 192.168.103.208*
- *nmap -p 139,445 192.168.103.208*
- User enumeration: *nmap --script smb-enum-users.nse 192.168.103.208*
- Group enumeration: *nmap --script smb-enum-groups.nse --script-args smbusername=vagrant,smbpass=vagrant 172.30.1.22*
- Network Share enumeration: *nmap --script smb-enum-shares.nse -p 445 192.168.103.208*
- *nmap -sC 192.168.88.251*
- *nmap -sV --script=http-enum -p 80 192.168.103.208*
- General scanning: *enum4linux 192.168.103.208*
- Nmap NSE scan to discover vulnerabilities: *nmap --script vuln 192.168.103.208*

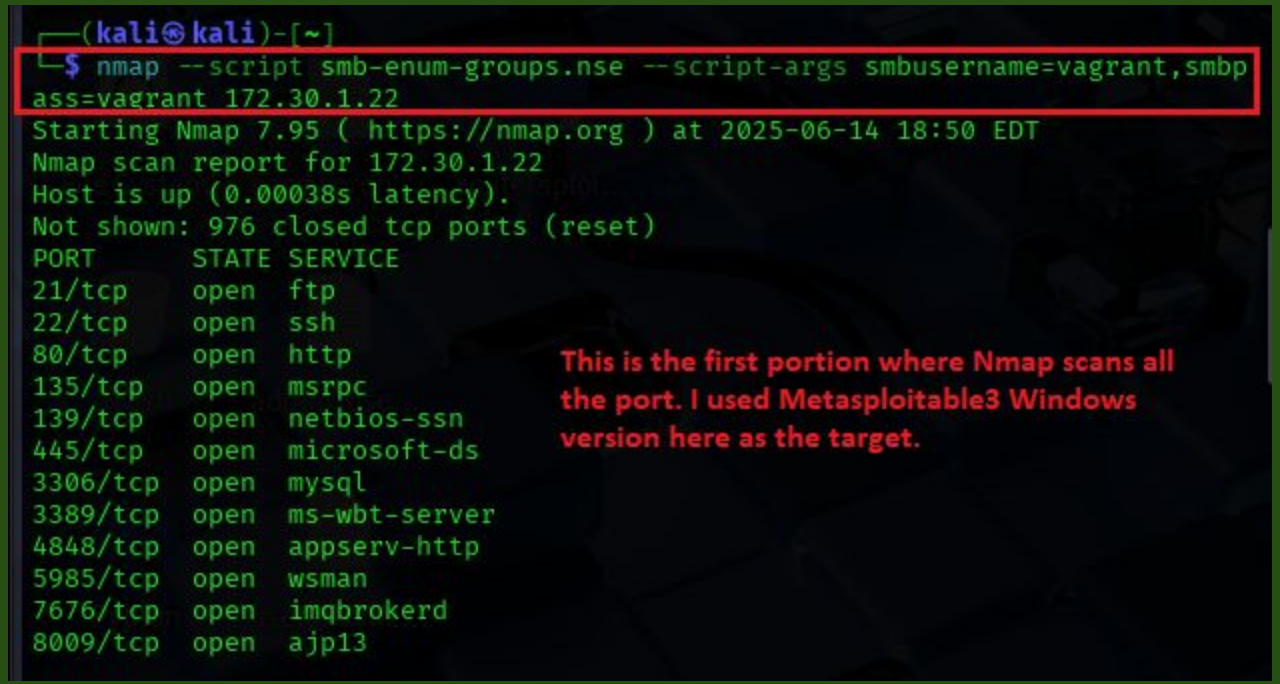
Using Nmap: More on the Group Enumeration Scanning

This technique runs best if you have compromised the target's username and password:
Group enumeration: *nmap --script smb-enum-groups.nse --script-args smbusername=vagrant,smbpass=vagrant 172.30.1.22*
The "*smbusername=vagrant"* means the attacker has confirmed the username to be vagrant, same for the "*smbpass=vagrant".*

For this command to work on your OWASP, use "*smbusername=root*" and "*smbpass=owaspbwa*" then use the IP address of your OWASP. Even at that, you may not see the host script result as you would see on a Windows based system.

You can use this command: "*nmap -p 445 --script smb-enum-groups --script-args smbuser=root,smbpass=owaspbwa 192.168.103.208*". Replace the IP with your OWASP IP.
Check the next slide for the screenshot:

Using Nmap: More on the Group Enumeration Scanning



Check the next slide

Using Nmap: More on the Group Enumeration Scanning

```
Host script results:
| smb-enum-groups:
|   Builtin\Administrators (RID: 544): Administrator, vagrant, sshd_server
|   Builtin\Users (RID: 545): vagrant, sshd, sshd_server, leia_organa, luke_
skywalker, han_solo, artoo_detoo, c_three_pio, ben_kenobi, darth_vader, anak
in_skywalker, jarjar_binks, lando_calrissian, boba_fett, jabba_hutt, greedo,
 chewbacca, kylo_ren, pentester
|   Builtin\Guests (RID: 546): Guest, ben_kenobi
|   Builtin\Power Users (RID: 547): boba_fett
|   Builtin\Print Operators (RID: 550): jabba_hutt
|   Builtin\Backup Operators (RID: 551): leia_organa
|   Builtin\Replicator (RID: 552): chewbacca
|   Builtin\Remote Desktop Users (RID: 555): greedo
|   Builtin\Network Configuration Operators (RID: 556): anakin_skywalker
|   Builtin\Performance Monitor Users (RID: 558): lando_calrissian
|   Builtin\Performance Log Users (RID: 559): jarjar_binks
|   Builtin\Distributed COM Users (RID: 562): artoo_detoo
|   Builtin\IIS_IUSRS (RID: 568): darth_vader
|   Builtin\Cryptographic Operators (RID: 569): han_solo
|   Builtin\Event Log Readers (RID: 573): c_three_pio
|   Builtin\Certificate Service DCOM Access (RID: 574): luke_skywalker
|_  VAGRANT-2008R2\WinRMRemoteWMIUsers__ (RID: 1003): <empty>
```

You can see how Nmap enumerate the group starting from the admins to users.
This is a powerful detail we're accessing

Let’s connect!



Thank you for your time reviewing my work. If you’d like to
see more or get in touch, my contact information is provided below.

Email: lekeoti12@gmail.com
Phone: +234-813-581-6654
LinkedIn: www.linkedin.com/in/emmanueloti

Thank you!